

Lab: Blind OS command injection with time delays

1. Mục tiêu của bài lab

1. Hiểu cách hoạt động của lỗ hổng Blind OS Command Injection.
2. Xác định khả năng chèn lệnh hệ điều hành vào ứng dụng web.
3. Chứng minh lỗ hổng bằng cách tạo độ trễ 10 giây trong phản hồi của máy chủ.

2. Trả lời câu hỏi

What is Blind Command Injection, and how does it differ from classic command injection vulnerabilities?

→ Blind Command Injection là lỗ hổng cho phép kẻ tấn công chèn và thực thi lệnh hệ điều hành trên máy chủ, nhưng kết quả của lệnh không được hiển thị trực tiếp trên giao diện ứng dụng.

Điểm khác biệt là ở Command Injection thông thường, kẻ tấn công có thể nhìn thấy ngay đầu ra của lệnh được thực thi. Trong khi đó, với Blind Command Injection, lệnh vẫn được thực thi nhưng không có đầu ra trả về, khiến việc xác nhận khai thác thành công trở nên khó khăn hơn.

Discuss the challenges posed by Blind Command Injection, particularly in scenarios where the application does not return any direct output from executed commands. How can an attacker infer successful command execution in such cases.

→ Thách thức lớn nhất của Blind Command Injection là ứng dụng không trả về kết quả của lệnh, nên kẻ tấn công không thể quan sát trực tiếp đầu ra để xác nhận việc khai thác.

Để xác định lệnh có được thực thi hay không, kẻ tấn công thường sử dụng các kỹ thuật gián tiếp như tạo độ trễ thời gian (time-based attack), gửi yêu cầu DNS/HTTP ra máy chủ bên ngoài hoặc quan sát sự thay đổi trong hành vi của ứng dụng.

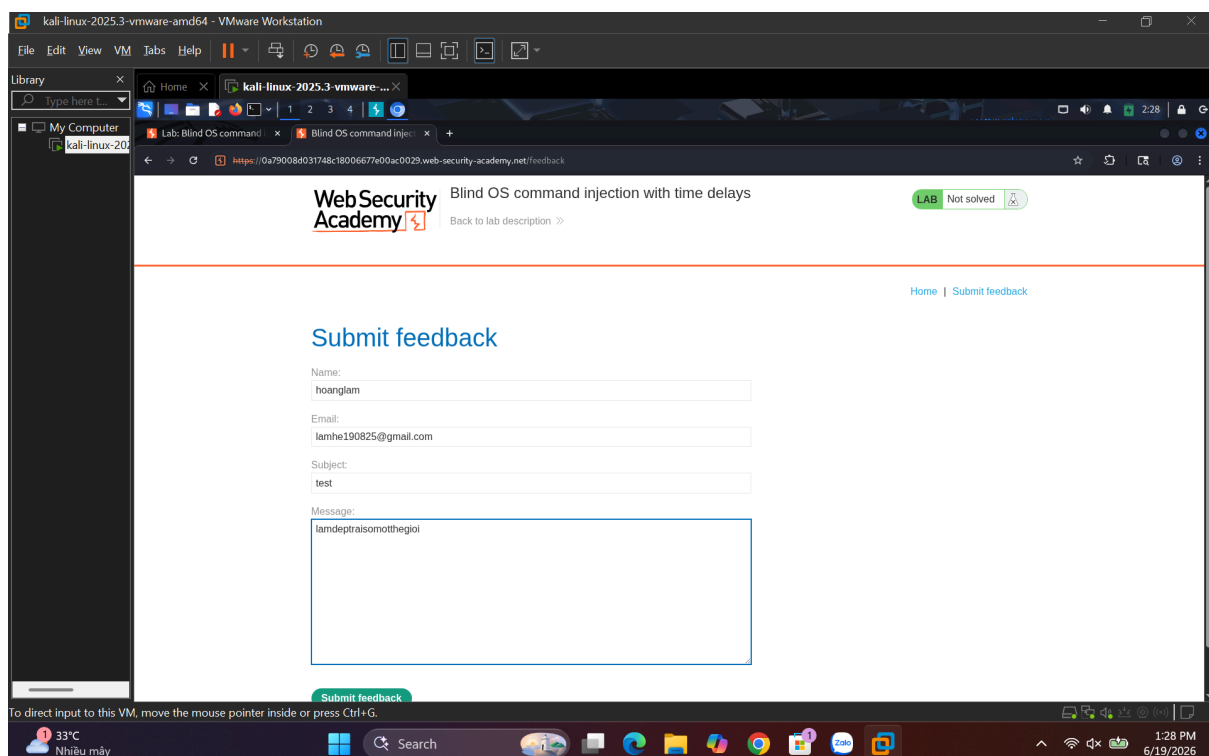
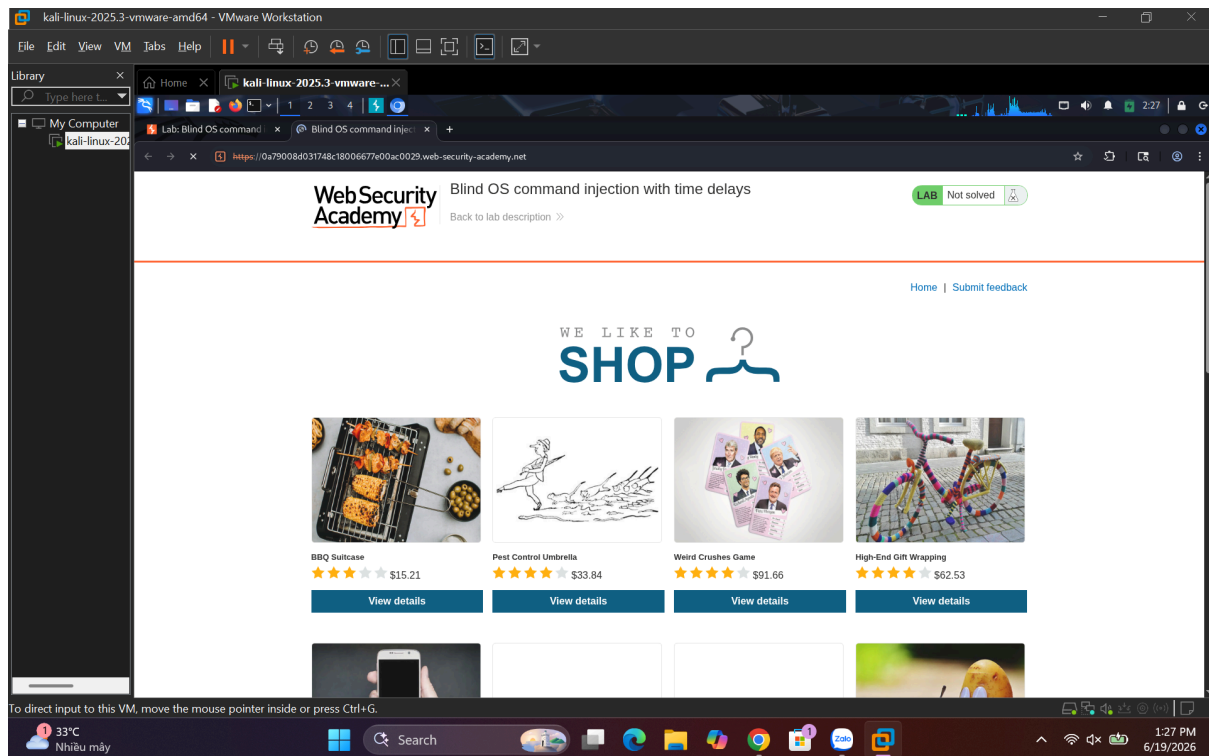
Trong bài lab này, kỹ thuật tạo độ trễ được sử dụng bằng cách chèn lệnh ping -c 10 127.0.0.1. Khi phản hồi của ứng dụng bị chậm khoảng 10 giây, có thể kết luận rằng lệnh đã được thực thi thành công và ứng dụng tồn tại lỗ hổng Blind Command Injection.

3. Chi tiết lab

B1. Truy cập chức năng Feedback

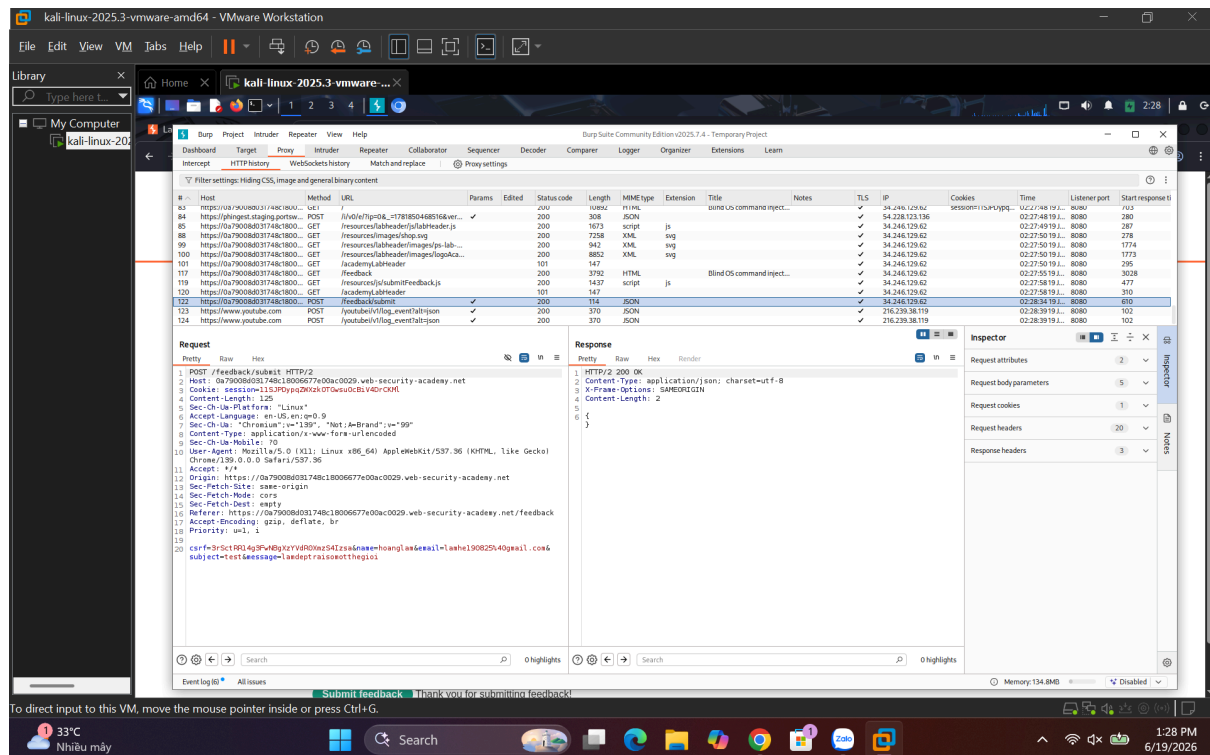
Mở ứng dụng và truy cập trang Feedback.

Điền các trường thông tin bất kỳ rồi gửi yêu cầu thông qua Burp Suite để chặn request.

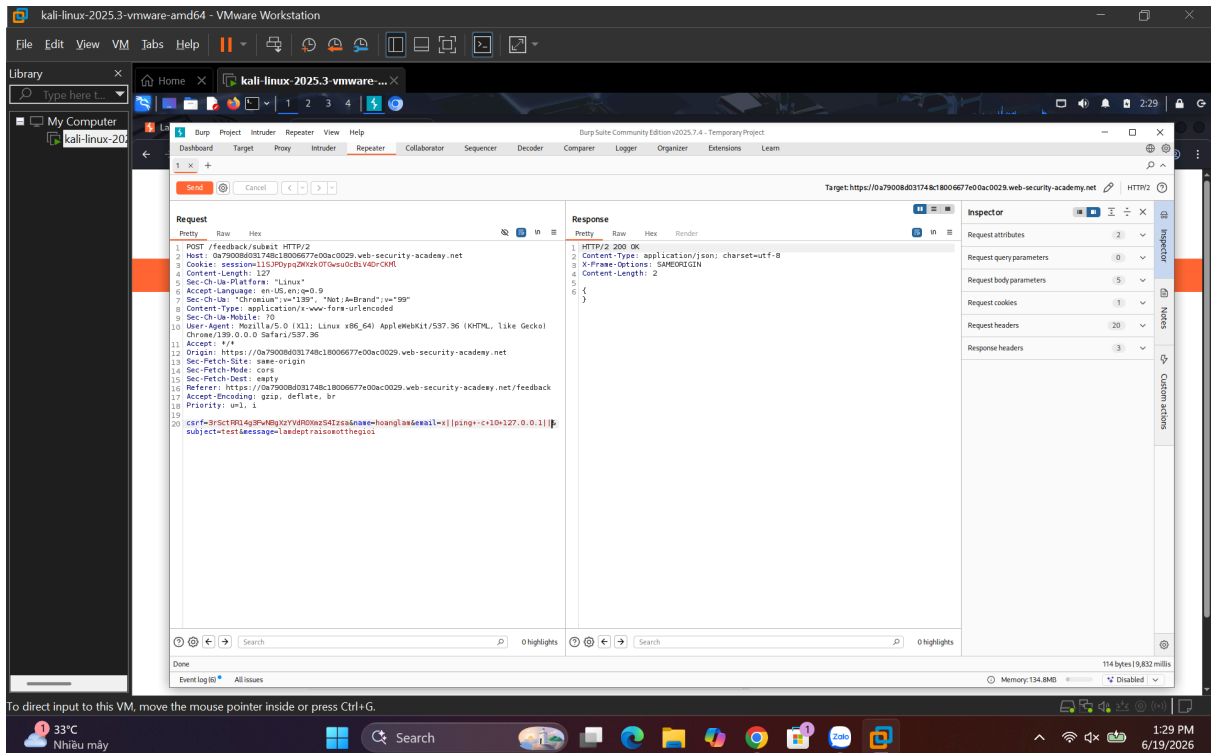


B2. Chặn request bằng Burp Suite

Gửi biểu mẫu Feedback và quan sát request chứa các tham số:
POST /feedback/submit
ta thấy dc name, email, subject và message



B3. Chuyển request sang Repeat
Chèn đoạn payload vào email
Thay từ email của mình thành `email=x||ping+-c+10+127.0.0.1||`
Sau đó send

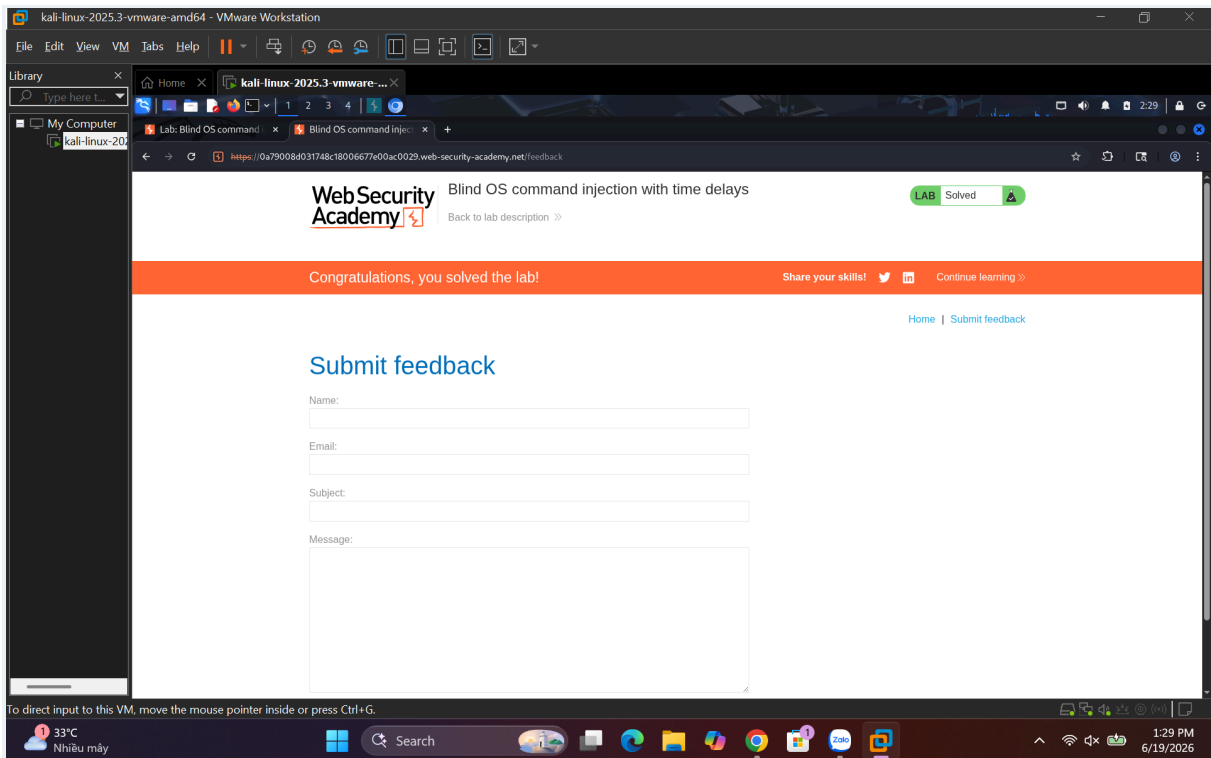


B4. Kết quả

Theo dõi thời gian phản hồi của ứng dụng.

Request mất khoảng 10 giây mới nhận được phản hồi từ máy chủ.

Điều này chứng minh payload đã được thực thi trên hệ điều hành của máy chủ.



* Giải thích payload:

- x là một lệnh không tồn tại nên sẽ thất bại.
- || là toán tử OR trong shell.
- Khi lệnh đầu tiên thất bại, shell sẽ thực thi lệnh phía sau.
- ping -c 10 127.0.0.1 gửi 10 gói tin đến localhost.
- Mỗi gói tin mất khoảng 1 giây nên tạo ra độ trễ khoảng 10 giây.